

Task 0 Policy Analysis

By Stephen Reilly | *Security Policy Analysis Series*

Q: Analyze the sample security policy below and provide a comprehensive assessment.

Sample Policy to Analyze

SECURITY POLICY

All employees should use good passwords. Don't share them.
IT will handle security stuff.
Report problems to someone.

Updated: Sometime last year

Part A: Missing Components

Missing Component	Why It's Important
Header Information (Version, Date, Owner)	Without version control and ownership, there's no way to verify which policy is current, who has authority to update it, or whether anyone is actually accountable for maintaining it. The vague "Sometime last year" update line tells you everything about how seriously this organization takes documentation.
Purpose Statement	A purpose statement explains <i>why</i> the policy exists and what it aims to achieve. Without it, employees lack context for why compliance matters — reducing buy-in and making the policy feel arbitrary rather than strategic.
Scope Definition	Scope defines <i>who and what</i> the policy covers — all employees? Contractors? Third-party vendors? BYOD devices? Cloud services? Without scope, there are inevitable gaps where people or systems fall outside the policy's reach, and ambiguous cases become unenforceable.
Specific Policy Statements	The existing language is vague to the point of uselessness. A policy needs measurable, auditable requirements — minimum password length, MFA mandates, acceptable use boundaries — so that compliance can be verified and violations can be clearly identified.
Roles and Responsibilities	"IT will handle security stuff" is not a role definition. You need clearly delineated responsibilities: who implements controls, who monitors, who investigates incidents, who approves exceptions. Without this, critical tasks fall through the cracks and there's no accountability when things go wrong.
Enforcement Section	Without stated consequences for violations and a defined enforcement process, the policy has no teeth. Employees need to understand that non-compliance has real outcomes, and management needs a consistent framework for addressing violations — otherwise enforcement becomes inconsistent and legally vulnerable.
Definitions	Terms like "good passwords," "security stuff," and "problems" are undefined and subjective. A definitions section ensures everyone interprets the policy the same way and reduces ambiguity that could be exploited or lead to inconsistent application.
Related Documents	No policy operates in isolation. References to related standards (NIST, ISO 27001), supporting procedures, incident response plans, and acceptable use policies create a coherent governance framework. Without cross-references,

Missing Component	Why It's Important
	the policy exists in a vacuum.
Review/Revision History	"Sometime last year" is not revision history. You need structured review cycles (e.g., annual), documented change logs, and approval records. This ensures the policy stays current with evolving threats, regulatory changes, and business needs — and provides an audit trail.

Part B: Weaknesses

Weakness	Problem	Impact
<i>"All employees should use good passwords"</i>	"Good passwords" is entirely subjective — no minimum length, complexity requirements, or mention of password managers or MFA. Also, "should" is non-mandatory language; "must" or "shall" is standard for policies.	Users will apply wildly different standards. An auditor would have no measurable criteria to assess compliance. The weak password risk — credential stuffing, brute force — remains completely unaddressed.
<i>"Don't share them"</i>	No specifics on what constitutes sharing (writing them down? sharing with IT? using shared accounts?). No mention of approved password managers or secure credential handling.	Employees may share credentials informally "for convenience," create shared admin accounts, or store passwords in plaintext — all common attack vectors — believing they're complying because "sharing" was never defined.
<i>"IT will handle security stuff"</i>	"Security stuff" is absurdly vague. Which IT team? What stuff? Is that endpoint hardening? Incident response? Vulnerability management? Access reviews? Also, security is everyone's responsibility — delegating it entirely to IT creates a dangerous single point of failure.	Non-IT staff will disengage from security entirely ("that's IT's job"). Within IT itself, nobody knows who owns what. Critical security functions will be assumed-covered but actually unowned.
<i>"Report problems to someone"</i>	"Someone" is not a contact. No specific team, role, email, phone number, or escalation path. No definition of what constitutes a "problem" worth reporting.	Incidents will go unreported because employees don't know who to tell. Time will be wasted figuring out the right person. Small issues that could indicate larger attacks will fester. This alone could turn a contained incident into a breach.
<i>"Updated: Sometime last year"</i>	No actual date, no version number, no record of what changed, no indication of when the next review is due. This suggests the policy receives little attention and may be significantly out of date.	The policy likely doesn't reflect current threats, technologies, or regulatory requirements. Auditors and regulators will flag this immediately. Employees won't trust its relevance, further undermining compliance.
<i>(missing) "Should" vs. mandatory language</i>	Throughout the policy, "should" implies a recommendation, not a requirement. Security policies must use prescriptive language ("must," "shall") to be enforceable and auditable.	The entire policy reads as optional guidance rather than binding requirements. In a breach scenario or legal proceeding, this weak language makes it extremely difficult to demonstrate that the organization

Weakness

Problem

Impact

enforced — or even intended to enforce — its own security standards.

Overall Assessment

This policy essentially functions as a decorative document rather than a governance instrument. It fails on nearly every dimension: it lacks specificity, accountability, enforceability, and maintainability. In a real-world scenario, an auditor would shred this, and in the aftermath of a breach, regulators and legal counsel would find it provides virtually no evidence of due care.

Part C: Rewritten Policy

INFORMATION SECURITY POLICY

Document Control

Field	Value
Policy ID	POL-SEC-001
Version	1.0
Effective Date	2026-07-01
Review Date	2027-07-01
Policy Owner	Chief Information Security Officer (CISO)
Approved By	[CEO Name], Chief Executive Officer
Classification	Internal

1. Purpose

This policy establishes mandatory requirements for information security across the organization to protect the confidentiality, integrity, and availability of company data, systems, and networks. It defines clear expectations for all personnel, mitigates the risk of security incidents, and ensures compliance with applicable regulations and industry standards.

2. Scope

2.1 Applicability

This policy applies to:

- All employees (full-time, part-time, temporary)
- Contractors and consultants
- Third-party vendors with system access
- Interns and volunteers with system access

2.2 Systems/Assets Covered

- All corporate networks, servers, and endpoints

- Cloud services and SaaS platforms under organizational control
- Company-issued and BYOD devices used for business purposes
- All data classified as Internal, Confidential, or Restricted
- Physical facilities housing IT infrastructure

2.3 Exclusions

- Publicly available marketing content (no classification required)
 - Personally owned devices with no organizational data access
 - Third-party systems governed by their own security policies (covered under vendor agreements)
-

3. Policy Statements

3.1 Authentication and Credential Management

All users must authenticate using strong credentials and multi-factor authentication (MFA) to prevent unauthorized access.

Requirements:

- Passwords must be a minimum of 14 characters; passphrases are encouraged
- MFA must be enabled on all accounts that support it — no exceptions without written approval
- Passwords must not be shared, reused across accounts, or stored in plaintext
- An approved enterprise password manager must be used for credential storage
- Shared or generic accounts are prohibited unless formally approved through the exception process
- Default credentials on any system must be changed before deployment

3.2 Access Control

Access to systems and data must follow the principle of least privilege.

Requirements:

- Access is granted based on job function and business need only
- User access must be reviewed quarterly by department managers
- Access must be revoked within 24 hours of role change, termination, or contract end
- Privileged accounts must be inventoried, monitored, and require separate MFA
- Temporary access elevations must be time-limited and documented

3.3 Incident Reporting and Response

All personnel must report suspected security incidents promptly through defined channels so the organization can respond before damage escalates.

Requirements:

- All suspected security incidents must be reported to the IT Security Team within 1 hour of discovery via security@[company].com or the internal #security-incidents channel
- Incidents include but are not limited to: suspected phishing, unauthorized access, malware alerts, lost/stolen devices, and data exposure

- Personnel must not attempt to investigate or remediate incidents independently
 - The IT Security Team will triage, classify, and escalate incidents per the Incident Response Plan (IRP-001)
 - Post-incident reviews must be conducted for all medium- and high-severity incidents
-

4. Roles and Responsibilities

Role	Responsibilities
Executive Management	Approve this policy, allocate security budget and resources, champion a security-aware culture, receive quarterly risk briefings
CISO / IT Security Team	Own and maintain this policy, implement and monitor security controls, conduct threat assessments, manage incident response, deliver security training
Department Managers	Ensure team members complete required training, conduct quarterly access reviews, report observed risks, escalate concerns to IT Security
Human Resources	Process access revocation upon termination/role change, coordinate security awareness training enrollment, support enforcement actions
All Employees and Contractors	Comply with all policy requirements, complete annual security awareness training, report incidents promptly, protect credentials and sensitive data
IT Operations	Harden systems per security baselines, apply patches within defined SLAs, maintain asset inventory, support incident investigation

5. Compliance

5.1 Monitoring

The IT Security Team will continuously monitor authentication logs, network traffic, endpoint telemetry, and access patterns via deployed SIEM and EDR solutions. Automated alerts for policy violations (e.g., plaintext credential storage, disabled MFA) will be generated and triaged.

5.2 Reporting

IT Security will produce a monthly compliance dashboard covering: MFA adoption rate, training completion rate, open vulnerabilities, and incident metrics. A summary will be presented to executive management quarterly.

5.3 Auditing

An independent internal audit of policy compliance will be conducted annually. Findings will be documented, assigned risk ratings, and tracked to remediation. External audits may be conducted as required by regulatory obligations.

6. Enforcement

6.1 Violations

Violations of this policy may result in:

- Verbal warning and mandatory remedial training
- Written warning placed in personnel file

- Suspension of system access privileges
- Disciplinary action up to and including termination of employment or contract
- Legal action where applicable (e.g., data theft, intentional sabotage)

6.2 Reporting Violations

Report suspected policy violations to:

- **Email:** security@[company].com
- **Internal channel:** #security-incidents
- **Anonymous reporting:** [Company Ethics Hotline URL/Phone]
- **Direct contact:** CISO or any member of the IT Security Team

7. Exceptions

7.1 Exception Process

Exceptions to this policy require:

1. Written request submitted to the CISO via the Policy Exception Request Form (FRM-SEC-002)
2. Business justification explaining why compliance cannot be achieved
3. Formal risk assessment documenting residual risk
4. Defined compensating controls that mitigate the accepted risk
5. Formal approval and sign-off by the CISO and the requesting employee's VP/Director

7.2 Exception Duration

All exceptions must have a defined end date not exceeding 12 months. Exceptions will be reviewed quarterly and must be formally renewed or allowed to expire.

8. Definitions

Term	Definition
Multi-Factor Authentication (MFA)	An authentication method requiring two or more verification factors: something you know (password), something you have (token/device), or something you are (biometric).
Least Privilege	The principle of granting users only the minimum access necessary to perform their job functions.
Privileged Account	Any account with elevated permissions beyond standard user access, including administrative, root, or service accounts.
Security Incident	Any event that compromises or potentially compromises the confidentiality, integrity, or availability of organizational data or systems.
Compensating Control	An alternative security measure implemented when a primary control cannot be applied, providing equivalent risk mitigation.
SIEM	Security Information and Event Management — a platform that aggregates and analyzes log data from across the environment for threat detection.
EDR	Endpoint Detection and Response — monitoring and response tool deployed on endpoints to detect and contain threats.

9. Related Documents

- Acceptable Use Policy (POL-SEC-002)
- Incident Response Plan (IRP-001)
- Access Control Standard (STD-SEC-003)
- Data Classification Policy (POL-SEC-004)
- Vendor Security Management Policy (POL-SEC-005)
- NIST Cybersecurity Framework (CSF)
- ISO/IEC 27001:2022

10. Revision History

Version	Date	Author	Description
1.0	2026-07-01	[CISO Name]	Initial release — replaces legacy security policy dated ~2025

11. Acknowledgment

By accessing company systems, all users acknowledge they have read, understood, and agree to comply with this policy. For formal acknowledgment tracking, use the company's policy acknowledgment system.